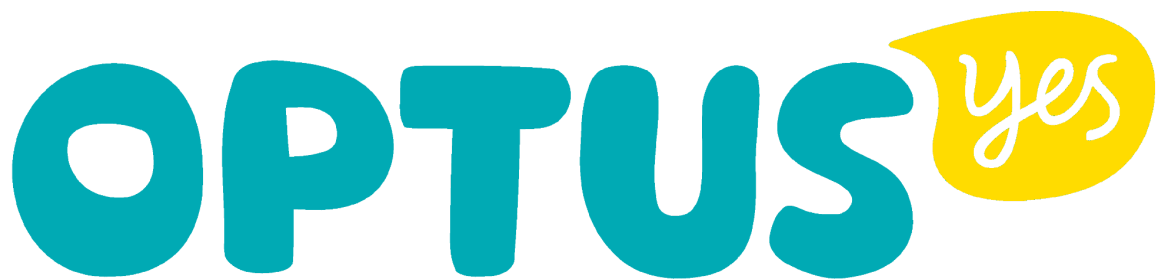


2022 Optus Cybersecurity Incident: Data Breach

William Lam

Year 12 Software Engineering



Introduction.....	2
Analysis of Security Vulnerabilities.....	2
Impact Assessment.....	4
Recommendations.....	5
Conclusion.....	5
Bibliography.....	6

Introduction

In 2022, Optus, an Australian telecommunications provider, had a data breach occur. Optus is the second largest Australian telecommunications company, after Telstra, and it covers approximately 98.5% of Australian customers with its 4G network, and it is currently doing a 5G rollout across the country.¹ It provides about 31% of all mobile and cell services in Australia.

The cyberattack occurred on the 22nd September 2022, with customers being notified 24 hours after it had occurred. Initially, Optus reported that the breach had led to the theft of around 150 000 customer records, however after further review, it was revealed that approximately 9.8 million records were stolen. This included names, phone numbers, birthdates, and email addresses with some users losing more critical data such as driver's licenses, Medicare numbers, addresses and passports.²

1. Optus. (n.d.). *Wholesale Mobile Network*. Optus.
2. The State of Queensland. (n.d.). *Optus data breach | Community support*. Queensland Government.

Analysis of Security Vulnerabilities

The Optus data breach was by an API which was exposed, unprotected and public. It lacked user authentication which meant any user on the internet could access the data behind it. The API (Application Programming Interface), was public facing whilst also housed critical data about its customers. An API should not be publicly accessible if it allows access into a business's core operations or sensitive data.³ Additionally, customer information was distinguished by incrementing values. For example, if a user had an ID of 2, the next would be 3. There was also a coding error which was patched on Optus's primary website, but was not implemented on a secondary website. This secondary domain was unused, but still accessible to the internet, leaving a large hole in Optus's security.⁴

The cybercriminals exploited these vulnerabilities to gain access to and steal customer information. According to the BBC, the attackers gained access to Optus via a freely accessible software interface.⁵ The attackers, one of them named Optusdata on a public forum, gained access through the unprotected API, "api.optus.com.au". Then through enumeration of the contactid field, they accessed and downloaded customer data.⁶ They used Insecure Direct Object Reference (IDOR). IDOR allowed the attackers to directly view and manipulate data without proper authentication. The attackers were able to do this due to a lack of proper access control, as well as the contactid field being sequential.

Optus failed to uphold the following software security principles; confidentiality, authentication, and authorisation. By allowing the attackers to access the data, confidentiality was breached. Confidentiality ensures that sensitive data is accessible to only those authorised. Poor access control paired with no encryption led to the data being easily transferred out. Authentication, the process of verifying users and systems, serves as the first line of defense against cyberattacks. It was breached as the public API allowed anyone on the internet to access Optus's network without identifying themselves. Authorisation, which determines the level of access users can have, sets access controls in place to ensure that the risk of unauthorised access to sensitive data is minimised. It uses role-based access

control (RBAC) and access control lists (ACLs) to do this. This was breached as the user had full access to customer data from the exposed API, as well as the secondary domain. Integrity, availability and accountability of the data were maintained.

Optus's approach to maintaining its customers data and ensuring its system remained secure was inadequate. The exposed API and domain served as the primary entry points for the attackers. It shows that Optus was not prepared for a data breach, and is not keeping their system up to date. Additionally, the way the data was handled, without masking or any encryption, allowed the attacker to use IDOR to exfiltrate data easily. The absence of access controls meant anyone, not just the attackers, could have access to the system. This shows that Optus being breached was only a matter of time, ultimately meaning that Optus was unprepared for such an attack. However, their reaction to the attack was much better due to their robust monitoring, despite being unable to prevent the attack.

Optus did not follow security by design principles. It had multiple points of entry, zero access control, and did not have the principle of least privilege (PoLP). The system was not built with security by design from the start.

Regulatory compliance is the practice of ensuring that systems adhere to laws, regulations and standards relevant to ensuring the protection, handling and processing of data. Optus was not compliant with most laws in the 2022 data breach. The Australian Information Commissioner (AIC), alleges that Optus failed to uphold the Privacy Act 1988, through not taking reasonable steps to ensure that their customer's data was secure.⁷ However, Optus did uphold the Notifiable Data Breaches (NDB) Scheme by alerting authorities and the public about the breach 24 hours after it occurred.

3. Kost, E. (2025, December 1). *3 minute read How Did the Optus Data Breach Happen?* UpGuard.
4. Vincent. (2024, December 16). *How did the Optus data breach happen and how to avoid it?* Corbado.
5. Turnbull, T. (2022, September 28). *Optus: How a massive data breach has exposed Australia.* BBC.
6. Kirk, J. (2022, September 25). *Optus Under \$1 Million Extortion Threat in Data Breach.* Bank Info Security.
7. Office of the Australian Information Commissioner. (2025, August 8). *Australian Information Commissioner takes civil penalty action against Optus.* Office of the Australian Information Commissioner.

Impact Assessment

The 2022 Optus data breach has left a lasting impact on the company. It has led to significant reform across the country, as well as sparking talks about Australian cybersecurity policies. There was a substantial amount spent on reconstruction, as well as reimbursement to customers.⁸ It is estimated 1.5 billion Australian dollars was lost in brand value. In the three months after the breach, approximately 65000 customers left Optus, which made up 1.1% of the total user base.⁹ The Chief Executive Officer, Kelly Bayer Rosmarin, resigned from their position not long after the breach. Additionally, a class action lawsuit has been filed against Optus as well as civil penalty proceedings by government regulators. Overall, this has left a devastating impact on Optus.

Individuals affected by the data breach had large amounts of personal information stolen. 9.8 million customers had their privacy violated, with Optus failing to secure their system. Information stolen included names, phone numbers, addresses, emails, passport numbers, Medicare numbers and drivers licenses. This has led to an increase in scam calls to those affected, as well as an increase in identity fraud. For example, an individual could be contacted through their phone number about a potential issue with their passport. This could then trick the victim into giving away private data such as financial information. Optus being breached has severely affected individuals, with some deciding to step away from using their service.

In general, the cybersecurity incident left a heavy impression on society. With Australian privacy laws, particularly the Privacy Act (1988), already being under scrutiny for being vague, the data breach has led many to believe that these laws are outdated. For example, the OAIC (Office of the Australian Information Commissioner) has filed for a civil action against Optus, citing that it has breached the Privacy Act.¹⁰ Ultimately, Optus's severe lack of cybersecurity has had profound, negative effects on the Australian population calling for change.

8. The State of Queensland. (n.d.). *Optus data breach | Community support*. Queensland Government.

9. Wiggins, J., & Smith, P. (2023, November 9). *Optus outage: Optus tries to staunch potential 'big loss of customers'*. AFR.

10. Office of the Australian Information Commissioner. (2025, August 8). Australian Information Commissioner takes civil penalty action against Optus. Office of the Australian Information Commissioner.

Recommendations

In order to prevent future cyberattacks, Optus should utilise and layer a variety of different techniques. Optus lacked confidentiality, authentication and authorisation. To begin, Optus should ensure that all unused domains are closed. This is what led to the original attack. Data masking, encryption and proper access controls must be employed to ensure confidentiality, which ensures that sensitive information only accessible to those authorised. Authentication must be upheld as a public API allowing any user to access critical data and extract it. Authentication involves the verification of identity, ensuring that only legitimate users can access the system, through strong password policies, and multi-factor authentication (MFA). Authorisation determines the level of access a given user has. Role-based access controls (RBAC) can be used to assign permissions based on a user's role. Additionally, the Principle of Least Privilege (PoLP) would aid immensely in ensuring that Optus remains secure. It ensures that users can only access what is needed for their role in the system, so they do not have improper access to deeper parts of the system. The data breach was believed to be a programming error which left a secondary domain open to exploitation.¹¹ To prevent this, peer reviewing as well as penetration testing should be conducted. Using these strategies, Optus can ensure that their system security is heightened.

These recommendations align with the secure coding practices that Optus is lacking. Peer reviewing and penetration testing ensure relevant security testing. The GDPR (2018) enforces strict laws regarding data protection laws. These recommendations were based on the main principles of the GDPR¹², therefore ensuring that Optus follows the legislation. For example, using encryption ensures that Optus follows Principle 6: Integrity and Confidentiality.¹³ Additionally, the recommendations also align with the Australian Privacy Act (1988)¹⁴. It ensures that Optus keeps the privacy and security of their customers' data as its biggest priority, to prevent such an incident from occurring again. Therefore, these recommendations will immensely aid Optus in ensuring security as well as compliance.

11. Murphy, H. (2024, June 19). Optus cyber attack could have been prevented four years prior, ACMA says. ABC News.
12. Information Commissioner's Office. (2023, May 19). A guide to the data protection principles. A guide to the data protection principles.
13. Welford, B. (n.d.). What is GDPR, the EU's new data protection law? - GDPR.eu. GDPR compliance.
14. Office of the Australian Information Commissioner. (n.d.). Australian Privacy Principles quick reference.

Conclusion

In conclusion, the 2022 Optus data breach has emphasised the importance of secure software development. A simple programming mistake has led to a massive large scale attack, leaving customers vulnerable. Optus has taken significant steps to rebuild, with the Australian government looking to reform major laws regarding such incidents.

Bibliography

Information Commissioner's Office. (2023, May 19). *A guide to the data protection principles*.

A guide to the data protection principles. Retrieved December 11, 2025, from

<https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/data-protection-principles/a-guide-to-the-data-protection-principles/>

Jackson, L. (2023, November 19). *Australian telco Optus' CEO quits after network outage*.

Reuters. Retrieved December 11, 2025, from

<https://www.reuters.com/business/media-telecom/australian-telco-optus-ceo-resigns-days-after-network-wide-outage-2023-11-19/>

Kirk, J. (2022, September 25). *Optus Under \$1 Million Extortion Threat in Data Breach*. Bank

Info Security. Retrieved December 11, 2025, from

<https://www.bankinfosecurity.com/optus-under-1-million-extortion-threat-in-data-breach-a-20142>

Kost, E. (2025, December 1). *3 minute read How Did the Optus Data Breach Happen?*

UpGuard. Retrieved December 11, 2025, from

<https://www.upguard.com/blog/how-did-the-optus-data-breach-happen>

Murphy, H. (2024, June 19). *Optus cyber attack could have been prevented four years prior,*

ACMA says. ABC News. Retrieved December 11, 2025, from

<https://www.abc.net.au/news/2024-06-20/optus-hack/104002682>

Office of the Australian Information Commissioner. (n.d.). *Australian Privacy Principles quick reference*. Retrieved December 11, 2025, from

<https://www.oaic.gov.au/privacy/australian-privacy-principles/australian-privacy-principles-quick-reference>

Office of the Australian Information Commissioner. (2025, August 8). *Australian Information*

Commissioner takes civil penalty action against Optus. Office of the Australian

Information Commissioner. Retrieved December 11, 2025, from

<https://www.oaic.gov.au/news/media-centre/australian-information-commissioner-takes-civil-penalty-action-against-optus>

Optus. (n.d.). *Wholesale Mobile Network*. Optus. Retrieved December 11, 2025, from

<https://www.optus.com.au/wholesale/mobile-network>

Optus. (2022, September 22). *Optus notifies customers of cyberattack compromising customer information*. Optus. Retrieved December 11, 2025, from

<https://www.optus.com.au/about/media-centre/media-releases/2022/09/optus-notifies-customers-of-cyberattack>

The State of Queensland. (n.d.). *Optus data breach | Community support*. Queensland Government. Retrieved December 11, 2025, from

<https://www.qld.gov.au/community/your-home-community/cyber-security/cyber-security-for-queenslanders/case-studies/optus-data-breach>

Turnbull, T. (2022, September 28). *Optus: How a massive data breach has exposed Australia*. BBC. Retrieved December 11, 2025, from

<https://www.bbc.com/news/world-australia-63056838>

Vincent. (2024, December 16). *How did the Optus data breach happen and how to avoid it?* Corbado. Retrieved December 11, 2025, from

<https://www.corbado.com/blog/optus-data-breach>

Wiggins, J., & Smith, P. (2023, November 9). *Optus outage: Optus tries to staunch potential 'big loss of customers'*. AFR. Retrieved December 11, 2025, from

<https://www.afr.com/companies/telecommunications/optus-crisis-could-shake-up-telco-market-20231109-p5eisc>

Wolford, B. (n.d.). *What is GDPR, the EU's new data protection law? - GDPR.eu*. GDPR compliance. Retrieved December 11, 2025, from <https://gdpr.eu/what-is-gdpr/>